

Health Insurance Portability & Accountability Act (HIPAA) Policy

Security, Privacy & Breach Notification Rules for Electronic Protected Health Information (ePHI)

1. Scope & Minimum Necessary Rule

This policy establishes mandatory operational protocols for storing, transmitting, and analyzing electronic Protected Health Information (ePHI) in full accordance with 45 CFR Part 160 and Part 164 Subparts A, C, and E.

- Minimum Necessary Standard: Workforce members may only access or request the minimal amount of health information strictly necessary to fulfill authorized compliance audits or clinical evaluations.
- Role-Based Access Control (RBAC): Access to ePHI requires explicit approval from the Privacy Officer and is revoked immediately upon role transfer or employee termination.

2. Business Associate Agreements (BAAs)

Prior to disclosing or transferring any ePHI to cloud service providers, IT contractors, or analytics sub-vendors, ComplyAI must execute a formal, legally binding Business Associate Agreement (BAA). Any vendor refusing to execute a BAA is barred from ingesting or accessing healthcare datasets.

3. Technical Safeguards & Encryption Standards

All systems managing ePHI must enforce the following cryptographic standards:

1. Cryptographic Storage: All databases, object stores, and cold archives containing ePHI must enforce AES-256 encryption with HSM-managed master keys rotated every 180 days.
2. Transmission Security: End-to-end TLS 1.3 encryption is mandatory for all inbound and outbound ePHI communications.
3. Automatic Screen Inactivity Logoff: Workstations accessing healthcare portals must automatically terminate active sessions after 10 minutes of inactivity.
4. Audit Logging & Tracking: All read, write, update, and export events involving ePHI are immutably logged and retained for a minimum of 6 years pursuant to 45 CFR 164.316(b).

4. HIPAA Breach Notification Rule SLA

- Individual Notification: Impacted individuals must be notified in writing without unreasonable delay and in no case later than 60 calendar days following discovery of an unsecured ePHI breach.
- HHS OCR Notification: For breaches affecting 500 or more individuals, notice to the Secretary of Health and Human Services (HHS) must be provided contemporaneously with individual notices.
- Media Notification: Breaches impacting more than 500 residents of a single state or jurisdiction require formal notification to prominent regional media outlets within 60 calendar days.